29.1 Defending against cross-site scripting (XSS) attacks

In this section I describe XSS attacks and how attackers can use them to compromise your users. I show how the Razor Pages framework protects you from these attacks, how to disable the protections when you need to, and what to look out for. I also discuss the difference between HTML encoding and JavaScript encoding, and the effect of using the wrong encoder.

Attackers can exploit a vulnerability in your app to create XSS attacks that execute code in another user's browser. Commonly, attackers submit content using a legitimate approach, such as an input form, that is later rendered somewhere to the page. By carefully crafting malicious input, the attacker can execute arbitrary JavaScript on a user's browser and so can steal cookies, impersonate the user, and generally do bad things.

TIP For a detailed discussion of XSS attacks, see the "Cross Site Scripting (XSS)" article on the OWASP site: https://owasp.org/www-community/attacks/xss.

Figure 29.1 shows a basic example of an XSS attack. Legitimate users of your app can send their name to your app by submitting a form. The app then adds the name to an internal list and renders the whole list to the page. If the names are not rendered safely, a malicious user can execute JavaScript in the browser of every other user who views the list.